

FortyGuard API Evaluation Report

Sankalp Jha | DevSecOps and Network Architect | June 24, 2026

API-first evaluation of endpoint behavior, async task completion, validation, credit accounting, and documentation accuracy. API key and sensitive values are redacted from evidence.

Executive Summary

The final endpoint audit shows that FortyGuard's main API surface is functional when requests follow the documented shapes. Heatmap, Satellite View Segmentation, Street View Segmentation, and Environmental Parameters all submitted and completed successfully.

The highest-priority issue is validation before billing. A valid Heatmap FeatureCollection completed, but an intentionally unclosed polygon was also accepted, completed, and counted in Heatmap Generation credit usage. Invalid geometry should be rejected before job creation and should not consume credits.

The second major issue is operational developer experience: no rate-limit, retry, request-id, or remaining-credit headers were observed, and several docs pages do not match the live OpenAPI contract.

Evidence Files

- final_api_endpoint_audit.py
- evidence/final_api_endpoint_audit_2026-06-24.jsonl
- evidence/final_api_endpoint_summary_2026-06-24.md
- evidence/final_status_followup_2026-06-24.jsonl
- evidence/credits_usage_post_followup_2026-06-24.json

Endpoint Results

Endpoint / test	Result	Finding
GET /health	200	Healthy.
GET /ready	200	Ready.
GET /openapi.json	200	OpenAPI 3.1 schema available.
POST /v1/heatmap valid FeatureCollection	200 -> Completed	Returned map_data FeatureCollection with 180 features and stats_data.
POST /v1/heatmap unclosed polygon	200 -> Completed	Bug: invalid geometry accepted and completed.
POST /v1/satellite valid request	200 -> Completed	Returned coordinates, image metadata, original_image, and segmentation.
POST /v1/streetview valid request	200 -> Completed	Returned front street-view segmentation.
POST /v1/env_params OpenAPI shape	200 -> Completed	Returned metadata, parameters, and solar irradiance.
POST /v1/heat_intelligence invalid category	422	Enum validation works.
GET /v1/status/not-a-real-id	403	Ambiguous; 404 or clearer ownership/not-found error is better.
POST /v1/system/fetch-api-key-usage	200	Works, but docs label credits usage as GET/form-style.

Critical Findings

1. Invalid Heatmap Geometry Accepted and Charged

An unclosed polygon returned 200, completed, and produced map_data with 157 features. Credit usage after completion showed Heatmap Generation count 2 / credits 8440; the only two heatmap tasks in the run were the valid polygon and the unclosed polygon.

Recommendation: validate GeoJSON ring closure, minimum points, area, self-intersection, and region before enqueueing. Return 400/422 and never charge validation failures.

2. GeoJSON Contract Ambiguity

Docs use FeatureCollection, while wording like GeoJSON polygon can lead developers to send a raw Polygon. Earlier probing showed raw Polygon produced 500. The API should explicitly require FeatureCollection or support both safely.

3. Missing Operational Headers

No X-RateLimit-*, Retry-After, X-Credits-Remaining, X-Request-Id, or X-Correlation-Id headers were observed. A credit-based async API needs those headers for production operations and support correlation.

4. Documentation Mismatches

Credits usage is documented as a GET/form page, but the real API is POST /v1/system/fetch-api-key-usage. Environmental Parameters are described as customizable, but OpenAPI has no parameters selector. Satellite uses original_image while Street View uses original_image.

Credit Accounting Observation

Activity added by final run	Added count	Added credits
Tile Satellite Segmentation	1	14,400
Streetview Segmentation	1	8,600
Heatmap Generation	2	8,440
Environment Parameter Analysis	1	2,900
Total final-run delta		34,340

Because the two heatmap tasks were the valid FeatureCollection and the unclosed polygon, this supports the validation-before-billing finding.

Recommended Priorities

- Strict pre-enqueue GeoJSON validation and no billing for validation failures.
- Standard error envelope with code, message, doc_url, and request_id.
- Operational headers for credits, rate limits, retry, and request correlation.
- Document raw credits usage APIs and promote /openapi.json with Postman import.
- Add webhooks, task cancellation, idempotency keys, and batch endpoints.
- Clarify environmental parameter units, selectors, field names, and sentinel values.

Suggested Ratings

Area	Rating	Rationale
API	7/10	Main endpoint happy paths work, but validation, billing safeguards, docs accuracy, and operational headers need work.
Dashboard usability	6/10	Login/entry experience is polished, but authenticated map workflow still needs credentialed review.
Overall	7/10	Strong climate-tech foundation; highest-priority fixes are API trust and developer operations.

Final Takeaway

FortyGuard's API is much closer to usable than an initial rough probe suggested. The main endpoints work with documented request shapes. The strongest feedback is sharper: tighten validation before billing, make the OpenAPI contract precise, expose operational headers, and add async production features like webhooks, cancellation, and idempotency.